

Practical 3: Software Architecture Risk Analysis (SARA)

An **Architecture Risk Analysis (ARA)** is a thorough evaluation of design that helps assess whether your system follows secure design principles. Identifying and fixing security flaws earlier in the software development life cycle (SDLC) is more cost-effective, less disruptive, and requires less time than addressing issues after coding or quality assurance testing has taken place. Nevertheless, even for systems that are already developed or in operation, an ARA remains highly beneficial because both the functionality of an application and its potential vulnerabilities are continuously changing.

Source form:

<https://www.blackduck.com/services/security-program/software-architecture-design/risk-analysis.html>

Scenario:

You are part of a team designing a multi-tier web application for an online bookstore. The high-level architecture includes:

Frontend: A React-based SPA (Single Page Application)

Backend: Node.js REST API

Database: Oracle Database

Authentication: JSON Web Tokens (JWT)

Hosting: AWS (EC2 for backend, S3 + CloudFront for frontend)

Data exchanged over HTTPS

Task:

- Identify and explain **THREE (3)** key **architectural risks** in this setup.
- For each risk, suggest **ONE (1)** **mitigation strategy**.